

The Anatomy of Go Vulnerabilities



`security@golang.org`

Go doesn't have (interesting*) memory
corruption vulnerabilities

Security vulnerabilities are just
regular bugs that violate security
properties

We've triaged ~1,000 security reports
since 2020

Complexity of discovery



Panics (oob reads/writes, nil pointers)

Resource consumption (CPU or memory)

Logic bugs (it does what?)

Panics

```
hdr := parseHeader(data)
```

```
field := data[hdr.fieldPos:hdr.fieldPos+hdr.fieldLen]
```

Resource Consumption

```
hdr := parseHeader(data)
```

```
items := make([]int, hdr.items)
```

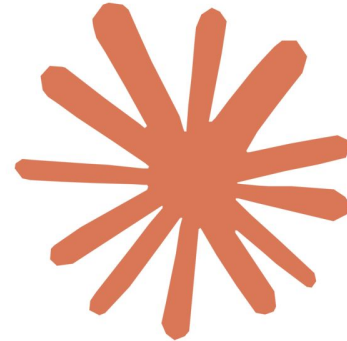
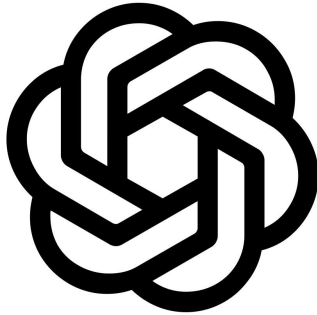
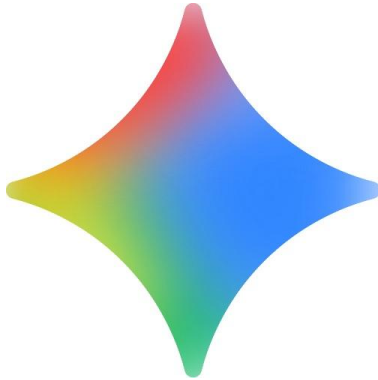

Logic bugs

```
246 247      switch n.Data {
247 248      case "iframe", "noembed", "noframes", "noscript", "plaintext", "script", "style", "xmp":

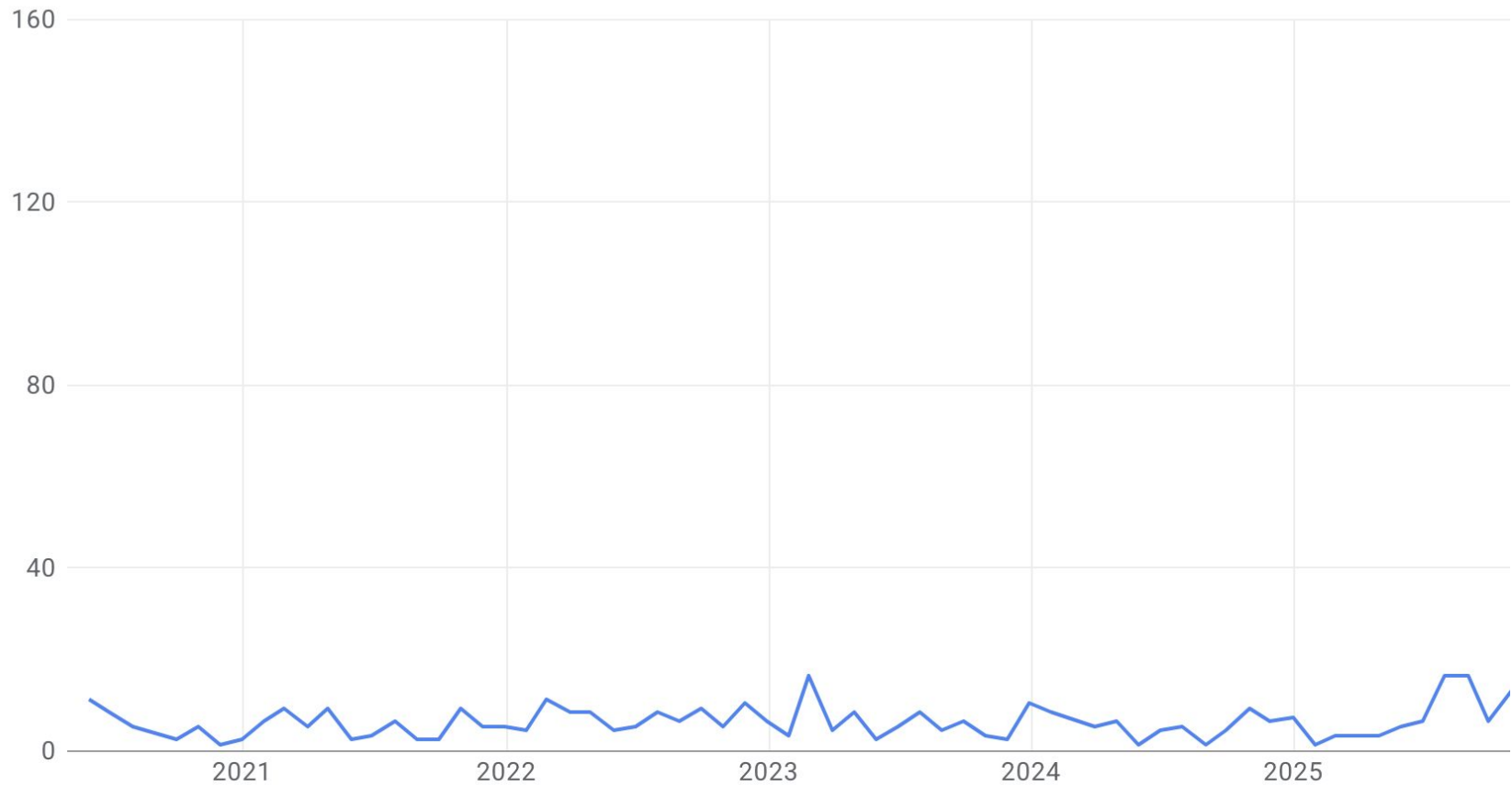
249 +          // We need to check if n is a node that was fostered from a HTML namespace
250 +          // into a non-HTML namespace (in which case, different rules apply to it).
251 +          // We do this by walking up the tree until we find a node with a non-empty
252 +          // namespace. If we find such a node, we also have to check if it's
253 +          // an HTML integration point. If it isn't, then the node we're currently
254 +          // looking at is foster-parented and we should return false.
255 +          for p := n.Parent; p != nil; p = p.Parent {
256 +              if p.Namespace != "" {
257 +                  if !htmlIntegrationPoint(p) {
258 +                      return false
259 +                  }
260 +                  break
261 +              }
262 +          }
```

Finding logic bugs tend to require deep understanding of the code, algorithms, and specifications

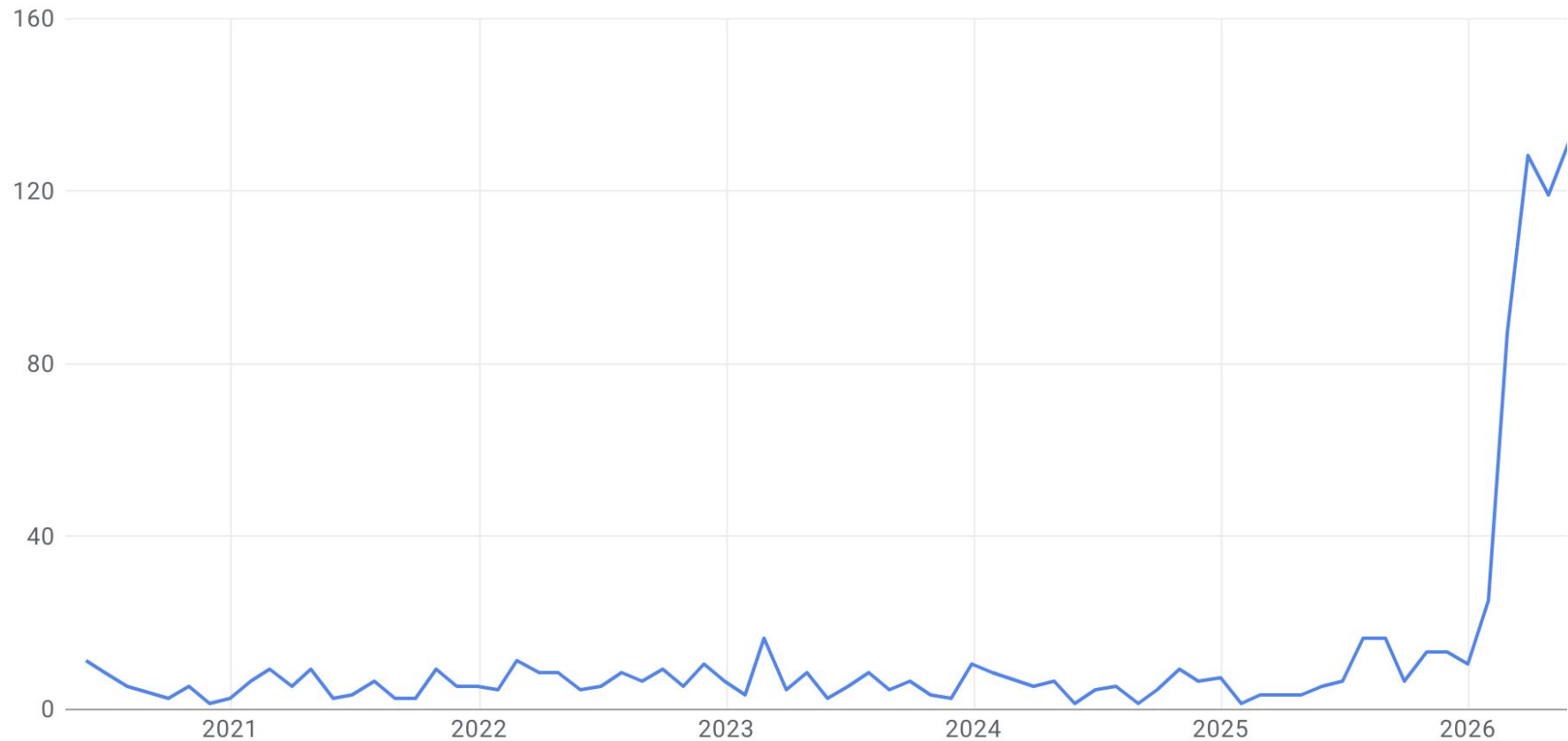
Computer, find me a security
vulnerability



Reports by Month



Reports by Month



LLMs are really good at finding bugs.

They aren't great (yet) at determining the security impact (~25% external acceptance rate).

> “Go doesn’t have (interesting*) memory corruption vulnerabilities”

* LLMs are really good at weaponizing vulnerabilities, does that change the calculus?

What can we do?

There is no silver bullet

You can't have security vulnerabilities
in code you never wrote

Tests, tests, tests

If LLMs can find bugs in giant code bases, it can also find them before they ever land!

Found something weird?

go.dev/security/policy

Thank you!